

MK FRAUD READINESS

Target-state design workshop

Turn the recorded assessment into owned decisions, sequenced actions and a board-ready checkpoint.

Kestrel Industrial Supply (Pty) Ltd

Fraud Readiness Strategy and Control Blueprint

Based on management's recorded Fraud Readiness assessment responses

The session should end with decisions, owners and a build sequence

This is a target-state design workshop. It moves from diagnosis to interpretation to design: understand the recorded position, choose treatment, define the target controls and agree how progress will be monitored.

By the end

- Confirm priority themes and scenarios.
- Define the target-state control blueprint.
- Choose decision options and accountable owners.
- Set sequencing, proof requirements and the next scorecard checkpoint.

Boundary

- Use the recorded assessment as the diagnosis baseline.
- Challenge interpretation and design assumptions in plain language.
- Do not convert discussion into an assurance conclusion.
- Keep operating effectiveness as a future measure, not a completed claim.

This report provides strategic fraud-risk analysis and control design based on management's recorded Fraud Readiness assessment responses. It does not independently verify operating effectiveness.

A 95-minute conversation with a clear output at every stage

TIME	CONVERSATION	PURPOSE	OUTPUT
15 min	Diagnosis readout	Create a shared view of the recorded position and exposure concentration.	Confirmed priority themes
20 min	Theme and scenario interpretation	Test how linked conditions could create exposure.	Agreed interpretation and scenario priorities
25 min	Target-state control design	Work through objective, owner, population, frequency, proof, escalation and measure.	Control blueprint adjustments
20 min	Decisions and trade-offs	Choose the route, owner and target period for priority decisions.	Decision record
15 min	Sequencing and scorecard	Confirm dependencies, management information and the next checkpoint.	Roadmap and scorecard

Facilitator cue

Keep the group moving from diagnosis to design. Capture every proposed action with owner, target period, dependency, proof and failure response.

Start with the recorded position and priority pathways

Use the diagnosis to focus the room. The question is: which conditions should the target state treat first, and why?

01 Fraud Leadership and Governance: Management owns fraud risk, while internal audit or assurance functions provide independent review where they exist.

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

Target direction: The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.

02 Fraud Incident Response: Evidence linked to suspected fraud is identified, preserved and handled appropriately.

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

Target direction: The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

03 Digital and Identity Fraud Risk: Access to sensitive digital systems, administrator rights and confidential data is restricted and reviewed.

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

Target direction: IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and Risk for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise.

Scenario lens

The recorded control condition is engaged through Continuous Improvement and Fraud Risk Monitoring: The organisation...

Define the control that would change the pathway

For each priority finding, design the control that management wants to operate. Work through objective, population, frequency, ownership, proof, escalation, measure and failure response.

Close the material control weakness recorded for "Management owns fraud risk, while internal audit or assurance functions provide independent review where they exist".

The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.

Owner: CEO / Managing Director · Population: The complete in-scope population for annual mandate review and quarterly exception reporting must be reconciled before sampling. · Measure: No key fraud control is both operated and independently certified by the same accountable function.

Close the material control weakness recorded for "The organisation periodically reviews its fraud risks and control environment".

The Head of Risk must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.

Owner: CEO / Managing Director · Population: The complete in-scope population for at least annually, and after any material incident or restructuring must be reconciled before sampling. · Measure: Every key control is evidence-tested within the review cycle, with lapses remediated by due date.

Validate that "The organisation monitors fraud trends affecting its sector, geography, customer environment or supplier base" operates to its exact expected standard.

Independently validate that "The organisation monitors fraud trends affecting its sector, geography, customer environment or supplier base" operates to the expected standard

(External trend monitoring is assigned, run on a defined rhythm, compared against internal

Close the material control weakness recorded for "The organisation has completed a structured fraud risk assessment within the past two years".

The Head of Risk must run a documented fraud risk assessment at least every two years using a repeatable method: scope the material processes and channels, identify fraud scenarios per process with the roles able to

execute them, rate likelihood and impact before and after existing controls, name a treatment owner and due date for every

Choose a route and make the trade-off explicit

A decision is complete when the selected option, owner, target period, consequence of delay and next deliverable are clear.

Approve accountable executive mandates and escalation authority for priority remediation.

Viable options

- Option A — deliver through existing internal ownership: cost — Internal capacity and management time.; benefit — Builds durable ownership inside the organisation.; trade-off — May move more slowly where capability is immature.
- Option B — use bounded specialist support: cost — Targeted specialist budget and handover effort.; benefit — Adds focused capacity against the named priority.; trade-off — Requires clear scope, procurement and transfer of ownership.
- Option C — combine internal ownership with targeted specialist support: cost — Combined internal capacity plus targeted specialist budget.; benefit — Keeps accountability internal while accelerating the priority design.; trade-off — Needs explicit boundaries so ownership and escalation are not diluted.

Deterministic recommendation

Name one accountable executive per linked control and approve a 30-day escalation route.

The recorded assessment links this decision to 8 material finding(s) and 8 risk(s). Management should confirm the final route, cost and delivery capacity.

Owner / target: CEO / Managing Director · 30 days

Selected option / owner / date / failure response:

Accountable ownership converts design into action

The accountable executive owns the change; the process owner operates it; the oversight function checks that the design is real and sustained.

PRIORITY ACTION	ACCOUNTABLE OWNER	PROCESS OWNER	OVERSIGHT	FIRST PROOF
Apply immediate escalation at "Any assurance reviewer assigned operational ownership of the control under review." and deliver the exact control design: The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.	CEO / Managing Director	Head of Risk and business control owners	Audit Committee / Internal Audit	Approved fraud-risk RACI; Audit-committee minutes showing independent reporting; Internal audit charter or assurance mandate
Apply immediate escalation at "Any unexplained custody gap, integrity mismatch or unauthorised repository access." and deliver the exact control design: The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.	General Counsel / COO	Investigation lead / Evidence custodian	Legal / Compliance	Chain-of-custody forms; Evidence register; Hash or seal records; Repository access log; Retention/legal-hold instruction
Apply immediate escalation at "Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours." and deliver the exact control design: IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and Risk for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise.	Chief Technology Officer	Identity and Access Management	Information Security / Internal Audit	Approval and business justification; Privileged-account register; Privileged-session/access logs; Quarterly independent recertification; Removal tickets
Apply immediate escalation at "A material process unmonitored, or a monitoring cycle missed without escalation." and deliver the exact control design: The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value	CFO / COO	Fraud monitoring owner	Head of Risk	Coverage report against process fraud maps; Monitoring output for recent periods; Population

Sequence the work so dependencies are visible

Sequence foundation, build and embed work across the four implementation horizons.

30 days

- Apply immediate escalation at "Any assurance reviewer assigned operational ownership of the control under review." and deliver the exact control design: The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes. · proof: Approved fraud-risk RACI; Audit-committee minutes showing independent reporting; Internal audit charter or assurance mandate · failure response: Any assurance reviewer assigned operational ownership of the control under review.

60 days

- Apply immediate escalation at "Any unexplained custody gap, integrity mismatch or unauthorised repository access." and deliver the exact control design: The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal. · proof: Chain-of-custody forms; Evidence register; Hash or seal records; Repository access log; Retention/legal-hold instruction · failure response: Any unexplained custody gap, integrity mismatch or unauthorised repository access.
- Apply immediate escalation at "Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours." and deliver the exact control design: IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and Risk for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise. · proof: Approval and business justification; Privileged-account register; Privileged-session/access logs; Quarterly independent recertification; Removal tickets · failure response: Any unknown or

Make the decision record durable

Decision record

Decision:

Options considered:

Selected path:

Owner:

Target period:

Next deliverable:

Scorecard record

Measure:

Population / frequency:

Threshold / escalation:

Owner:

Next checkpoint:

The next checkpoint should show ownership, proof and measures

Read the decisions back to the group. Confirm the owner, target period, proof requirement, escalation route and scorecard measure for every priority item.

Next checkpoint

Bring the blueprint register, completed proof requirements, action-ageing view and agreed effectiveness measures to the next management or board checkpoint.

- Owners have accepted the actions.
- Dates and dependencies are recorded.
- Proof requirements are specific enough to use.
- Residual risk and unresolved design choices are explicit.
- The next checkpoint has a date and an audience.

Owner review candidate — not market ready.